Incident Response Playbook — SSH Brute Force Attack

> **Standard:** NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide
> **Incident Type:** Credential Access — Brute Force (MITRE ATT&CK T1110)
> **Severity:** Medium
> **Status:** Resolved
> **Author:** Venkata Nukala
> **Date:** 2026-10-23

Incident Summary

Field	Value
Incident ID	IR-2026-001
Detection Time	2026-10-23 16:19:56 UTC
Containment Time	2026-10-23 16:20:14 UTC
Total Response Time	~18 seconds (automated)
Attack Type	SSH Brute Force
MITRE Technique	T1110 — Brute Force / Credential Access
Attacker IP	192.168.68.131 (Kali Linux VM)
Target IP	192.168.68.130 (Ubuntu Server — MrRobot)
Target Account	mrrobot
Detection Rule	Wazuh Rule 5758 — Maximum authentication attempts exceeded
Alert Level	8
Outcome	Detected and alerted. No successful authentication.

Phase 1 — Preparation

Security Controls in Place

Control	Tool	Configuration
Log collection	Wazuh Agent	`/var/log/auth.log` bind-mounted read-only into Wazuh Docker container
SIEM alerting	Wazuh 4.9.0	Rule 5758 enabled; alert level threshold set to 10 for email dispatch
Automated response	Shuffle SOAR	7-node pipeline: Webhook → Alert Parser → VirusTotal → AbuseIPDB → AI Triage → Email → SSH Auto-Block
IP reputation (vendors)	VirusTotal v3	80+ security vendor consensus — malicious, suspicious, harmless counts
IP reputation (crowd)	AbuseIPDB v2	Crowdsourced abuse confidence score 0–100% from community reports
AI-powered triage	Google Gemini gemini-3.5-flash	L1 SOC analyst triage report: executive summary, MITRE mapping, containment steps
Notification	Gmail SMTP	Automated email to SOC inbox — includes VirusTotal, AbuseIPDB, and AI triage in one alert

Monitoring Scope

- **In scope:** SSH authentication events on Ubuntu Server 192.168.68.130
- **Log source:** `/var/log/auth.log` — parsed by Wazuh agent running on the host

- **Alert threshold:** Level 8+ triggers Wazuh rule; level 10+ triggers Shuffle webhook and email

Known Environment

```
[Kali Linux 192.168.68.131]  ← Designated attacker VM
[Ubuntu Server 192.168.68.130]  ← Target / Wazuh-monitored
endpoint
[Wazuh Manager - Docker]  ← SIEM running on Ubuntu Server
[Shuffle SOAR - Docker]  ← Automation running on Ubuntu Server
```

Phase 2 — Detection & Analysis

2.1 Initial Detection

At **16:19:56 UTC**, Wazuh fired **Rule 5758** against the Ubuntu Server agent (`MrRobot`):

```
Rule ID:      5758
Description:  Maximum authentication attempts exceeded
Level:        8
Agent:        MrRobot (192.168.68.130)
Source IP:    192.168.68.131
Target User:  mrrobot
Log Source:   /var/log/auth.log
MITRE ID:     T1110
Tactic:       Credential Access
Technique:    Brute Force
```

2.2 Attack Reconstruction

The attacker (`192.168.68.131`) ran Hydra against the SSH service on the target:

```
        hydra -l mrrobot -P /usr/share/wordlists/rockyou.txt ssh://
192.168.68.130 -t 4 -V
```

- **Wordlist:** `rockyou.txt` (~14 million passwords)
- **Threads:** 4 concurrent SSH connections
- **Target account:** `mrrobot`
- **Pattern:** Rapid sequential failed authentication attempts — matched Rule 5758 signature

2.3 Automated Enrichment (Shuffle SOAR)

Shuffle received the Wazuh webhook at **16:19:56** and completed the full 7-node pipeline by **16:20:14** (18 seconds total):

Node 1 — Wazuh Alert (Webhook Trigger): Received full Wazuh alert JSON payload from Wazuh manager

Node 2 — Alert Parser: Extracted all fields from webhook payload — source IP, rule ID, severity, MITRE ID, agent name

Node 3 — VirusTotal v3: Queried attacker IP `192.168.68.131` against 80+ security vendors


```
{
  "malicious": 0,
  "suspicious": 0,
  "undetected": 36,
  "harmless": 56,
  "timeout": 0
}
```


Node 4 — AbuseIPDB Check: Queried crowdsourced abuse database for attacker IP
`abuseConfidenceScore: 0%` — internal lab IP with no community abuse reports (expected for homelab)
`HTTP 200 — success: true`

Node 5 — AI Triage (Google Gemini gemini-3.5-flash): Generated L1 SOC analyst triage report
`HTTP 200 — modelVersion: gemini-3.6-flash`
Output included: executive summary, MITRE T1110 mapping, true/false positive probability, 3-step containment recommendations

Node 6 — SOC Notification (Email): Enriched alert delivered to SOC inbox
`success: true — Email sent to nukalavenkatanarsimhabharghav@gmail.com`
Body: rule description, attacker IP, target host, severity, MITRE ID, VirusTotal count, AbuseIPDB score, full AI triage analysis

Node 7 — SSH Auto-Block: SSH command executed on Ubuntu Server via Shuffle SSH integration
`success: true — sudo ufw insert 1 deny from 192.168.68.131`
UFW deny rule inserted at **position 1** (above all allow rules) — attacker IP fully blocked at firewall level

2.4 Threat Assessment

Factor	Assessment
Attacker IP — vendor consensus	Clean (VirusTotal: 0 malicious, 56 harmless) — internal lab IP as expected
Attacker IP — community reports	0% abuse confidence score (AbuseIPDB) — no community

Factor	Assessment
	reports; expected for internal lab IP
AI triage verdict	True Positive — Gemini confirmed active brute force with high confidence, mapped to T1110
Authentication success	No successful logins detected in auth.log
Lateral movement	No — attack contained to SSH on single host
Data exfiltration	No evidence
Persistence	No — no new accounts, cron jobs, or SSH keys observed
Severity	**Medium** — active brute force, no breach

Phase 3 — Containment, Eradication & Recovery

3.1 Immediate Containment

Action	Method	Status
Block attacker IP at firewall	`ufw insert 1 deny from 192.168.68.131`	✅ **Automated via Shuffle SOAR**
Kill active SSH sessions from attacker	`ss -tp | grep 192.168.68.131` → `kill <pid>`	✅ Recommended (manual)
Temporarily disable SSH password auth	Set `PasswordAuthentication no` in `/etc/ssh/sshd_config`	✅ Recommended (manual)

```
# Block attacker IP — AUTOMATED by Shuffle SOAR SSH node
# Shuffle executes: sudo ufw insert 1 deny from <attacker_ip>
# Rule lands at position 1 — above all allow rules
sudo ufw status numbered
# Expected: [ 1] Anywhere  DENY IN  <attacker_ip>

# Verify no active sessions
ss -tp | grep 192.168.68.131
```

```
# Restart SSH after config change
sudo systemctl restart sshd
```

3.2 Eradication

Verify no successful authentication occurred during the attack window:

```
# Check for successful logins from attacker IP in the attack window
grep "Accepted" /var/log/auth.log | grep "192.168.68.131"

# Check for new user accounts created
grep "useradd\|adduser" /var/log/auth.log

# Check for new SSH authorized keys
cat /home/mrrobot/.ssh/authorized_keys
```

Expected result: No output — confirms no breach occurred.

3.3 Recovery

Since no successful authentication occurred, no system recovery is required.

If a breach had occurred: 1. Isolate host from network immediately 2. Preserve disk image for forensic analysis 3. Rotate all credentials on the affected host 4. Audit all accounts for unauthorized changes 5. Restore from last known-good snapshot if compromise is confirmed

3.4 Hardening Recommendations

Recommendation	Priority	Implementation
Disable SSH password auth; use key-based auth only	High	`PasswordAuthentication no` in `/etc/ssh/sshd_config`
Install and configure `fail2ban`	High	Auto-ban IPs after 5 failed attempts
Change SSH from default port 22	Medium	`Port 2222` in `/etc/ssh/sshd_config`
Restrict SSH access by IP allowlist	Medium	`ufw allow from <trusted_ip> to any port 22`
Enable MFA for SSH	Medium	`libpam-google-authenticator`

Phase 4 — Post-Incident Activity

4.1 Timeline of Events

Time (UTC)	Event
16:19:56	Hydra brute force begins from 192.168.68.131
16:19:56	Wazuh Rule 5758 fires — alert level 8
16:19:56	Shuffle webhook triggered — Node 1 (Wazuh Alert) receives payload
16:19:57	Node 2 (Alert Parser) extracts all fields — srcip, rule.id, rule.level, mitre.id, agent.name
16:20:05	Node 3 (VirusTotal) returns — 0 malicious, 56 harmless
16:20:06	Node 4 (AbuseIPDB) returns — abuseConfidenceScore: 0%
16:20:10	Node 5 (AI Triage) returns — Gemini gemini-3.6-flash L1 triage report generated
16:20:10	Node 6 (SOC Notification) — enriched email delivered to SOC inbox with all enrichment data
16:20:14	Node 7 (SSH Auto-Block) — `ufw insert 1 deny from 192.168.68.131` executed on target host
16:20:14	UFW deny rule confirmed at position 1 — attacker fully blocked
16:20:14	Incident detected, dual-enriched, AI-triaged, notified, and contained — **total automated response: 18 seconds**

4.2 Lessons Learned

What worked well: - Wazuh Rule 5758 fired immediately on brute force pattern — no manual review needed - MITRE T1110 mapping was automatic — no analyst effort required for classification - Full 7-node pipeline completed detection, dual-

source enrichment, AI triage, notification, and firewall block in 18 seconds - VirusTotal + AbuseIPDB dual enrichment gave two independent IP reputation signals in a single alert - Gemini AI generated a complete L1 triage report (executive summary, MITRE mapping, containment steps) with no analyst input - AbuseIPDB confidence score added crowdsourced threat context that pure vendor-scan tools don’t provide

What needs improvement:

Gap	Impact	Fix
Alert threshold tuned too low initially (level 3)	200+ emails from one scan	Always set threshold before running attacks
No dedicated Wazuh agent on Kali attacker VM	Attacker-side visibility missing	Install agents on all VMs from the start
Gemini response in email includes reasoning blob	AI triage section shows internal JSON in notification	Use `parts.1.text` path instead of `parts.0.text` for clean response only
UFW allow rule for SSH uses broad “Anywhere” scope	Legitimate SSH also blocked if IP rotates	Restrict `ufw allow` to trusted management IPs only
AbuseIPDB score 0% for internal lab IPs	Less meaningful for homelab testing	Expected limitation — score is meaningful for real external attacker IPs

4.3 Metrics

Metric	Value
Mean Time to Detect (MTTD)	< 1 second (automated rule)
Mean Time to Respond (MTTR)	18 seconds (automated enrichment + notification + firewall block)
False Positive Rate	0% — attack was real and correctly classified
Alerts generated	1 (after threshold tuning to level 10)

Appendix — Evidence

Artifact	Description	Location
`wazuh alert.png`	Wazuh Discover — Rule 5712 fired, level 10, MITRE T1110 (re-test run, 2026-10-25)	GitHub repo
`debug1.png`	Shuffle execution overview — FINISHED, webhook payload with rule_id 5712	GitHub repo
`debug2.png`	Alert Parser node — parsed Wazuh alert JSON payload, all_fields extracted	GitHub repo
`debug3.png`	VirusTotal Enrichment — status 200 for 192.168.68.131	GitHub repo
`debug4.png`	AbuseIPDB Check — status 422 (private IP not scored; expected in lab)	GitHub repo
`debug5.png`	AI Triage — Gemini gemini-3.6-flash, status 200	GitHub repo
`debug6.png`	SOC Notification email sent + SSH Auto-Block “Rule inserted”	GitHub repo
`email alert.png`	Gmail inbox — alert with VirusTotal result and full Gemini triage report	GitHub repo
`final shuffle workflow.png`	Shuffle Build view — all 7 nodes visible with connections	GitHub repo
`Wazuh Enrichment.json`	Full Shuffle workflow export — 7-node pipeline	GitHub repo

Artifact	Description	Location
	importable into any Shuffle instance	

Playbook written in accordance with NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide.
Framework reference: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf